

Evaluating Bias, Fairness, and Trustworthiness of Open Source LLMs in Phishing Susceptibility Judgements

Abstract

This report evaluates whether open source large language models (LLMs) make fair, evidence based, and trustworthy decisions when asked to check the most phishing vulnerable persona from a small set of generated profiles. Using the fixed assignment prompts, 15 open source models from 5 provider families were tested: Qwen, Mistral, Google Gemma, Falcon, and Microsoft Phi. The benchmark produced 899 valid raw prompt pairs; after filtering, 837 analysis ready pairs and 2,511 persona level rows remained. The study uses an adapted DecodingTrust style trustworthiness framing, focusing on fairness related selection patterns, stereotype sensitive explanation quality, and output reliability [1].

The strongest quantitative result was persona order bias: P3 was selected 40.26% of the time versus P1 at 24.73% ($\chi^2=31.34$, $p<.001$, $V=0.137$). Gender and broad location region were not statistically significant. Age, experience, and education were significant but with small effect sizes, suggesting tendencies rather than strong bias. A manual qualitative review of a reproducible 25% sample ($n=209$) found 86.60% evidence supported explanations. Qwen showed the strongest qualitative performance (97.67% evidence supported); Mistral the weakest (73.81%). The main concerns are persona order bias, provider level inconsistency, and a minority of weak or stereotype based explanations. These findings show LLM outputs should be treated carefully before use in phishing related profiling or security decision support.

1. INTRODUCTION

Large language models are increasingly used in decision making processes, including security related tasks such as phishing detection, triage, and user risk assessment. However, even when these systems appear useful, they may still produce unfair, unreliable, or weakly justified outputs. This matters in phishing related tasks because decisions about who is "most vulnerable" can translate into profiling, trained, or treated in real settings. According to DecodingTrust, the criteria of evaluating large language models should go beyond effectiveness and consider factors like fairness, stereotyping biases, and robustness [1].

This report evaluates whether open source LLMs make fair, evidence based, and trustworthy judgements about phishing susceptibility. The task follows the assignment's fixed two prompt design. In Prompt 1, each model generated three personas. In Prompt 2, the model selected the persona it considered most vulnerable to phishing and explained why. This structure makes it possible to evaluate not only who was selected, but also how the models justified their choices.

This study is informed by two broad strands of prior work. First, trustworthiness benchmarking work shows that model quality cannot be reduced to a single performance measure, because fairness, robustness, and explanation quality may all fail even when an answer appears plausible [1]. Second, phishing susceptibility research shows that some vulnerability related factors such as lower digital awareness, lower experience, higher communication exposure, and some forms of social influence can be genuine risk factors, so not every difference should automatically be treated as unfair bias [4][5][6][7].

The research gap that motivates the current paper includes the absence of previous analyses on how various provider families evaluate their vulnerability to phishing attacks via one comparison task using fixed persona. This study positions itself as a domain specific open source mini benchmark combining trustworthiness framing from DecodingTrust with phishing susceptibility reasoning, provider comparison, and explanation auditing [1][4]. The overall aim is not only to find bias, but to evaluate whether these models make phishing susceptibility decisions in a way that is fair, interpretable, and trustworthy.

2. LITERATURE REVIEW

2.1 Trustworthiness Framing

DecodingTrust provides the main benchmark framing for this study. It argues that LLM trustworthiness should be assessed across multiple dimensions rather than by accuracy alone [1]. This is directly relevant here because a model can produce a convincing phishing vulnerability judgement while still relying on unstable prompt structure, demographic shortcuts, or weak reasoning. In the current project, DecodingTrust is not reproduced as a full benchmark; instead, its evaluation logic is adapted to a phishing vulnerability task, with emphasis on fairness related selection differences, explanation quality, and robustness to prompt structure.

Recent positional bias work strengthens this framing further. Menschikov et al. show that LLM outputs can change systematically depending on position in a list, and that this is a genuine trustworthiness issue rather than a random formatting artifact [2]. This directly supports the interpretation of persona order bias in the results below.

2.2 Bias, Stereotypes, and Explanation Quality

StereoSetis useful for defining what stereotype bias means in language model evaluation [3]. CrowS-Pairs strengthens this by showing how benchmark design can explicitly test whether a model prefers stereotype consistent wording over anti stereotypical alternatives [8]. These papers do not evaluate phishing directly, but they provide a strong benchmark idea: a model should not rely on unsupported demographic assumptions as a shortcut. In this report, a phishing explanation is treated as stereotype or bias related when it uses demographic attributes such as age or region as a direct shortcut for vulnerability without a stronger evidence based mechanism.

At the same time, phishing literature suggests it is important not to overclaim bias. Zhuo et al. show that phishing susceptibility is influenced by a combination of human, social, technical, and contextual factors [4]. Parsons et al. show that phishing susceptibility is linked to broader social influence patterns, not just simple demographic categories [5]. Diaz et al. show that real world phishing susceptibility patterns are shaped by behavioural context and user behaviour rather than one

isolated demographic trait [6]. The anti phishing intervention literature identifies multiple dominant user, technical, and organisational factors rather than a single simple vulnerability profile [7]. These studies support a more careful interpretation: some factors may be real phishing risk factors, while unsupported demographic shortcutting should still be treated as a trustworthiness problem.

2.3 Positioning of This Study

Most prior benchmark studies examine broad trustworthiness categories, while this project applies those ideas to a specific security context: phishing vulnerability profiling. The contribution of this report is that it compares 15 open source models across 5 provider families using fixed prompts, repeated runs, quantitative analysis, provider comparison, automated reasoning theme coding, and manual qualitative review making it possible to evaluate both outputs and the reasoning behind them.

The literature also informed specific design decisions. DecodingTrust motivated the multi-dimensional trustworthiness framing [1]. Position of Uncertainty informed the interpretation of persona order effects as a meaningful robustness issue [2]. StereoSet and CrowS-Pairs informed the treatment of unsupported demographic shortcutting as stereotype style reasoning in the qualitative layer [3][8]. The phishing susceptibility papers informed the distinction between evidence supported phishing risk factors and unsupported or harmful assumptions [4][5][6][7].

3. RESEARCH QUESTIONS

This study addresses five research questions:

1. Do open source LLMs introduce representation bias when generating personas for a phishing susceptibility task?
2. Are phishing vulnerability selections associated with demographic, educational, occupational, regional, experience, personality, or technology use attributes?
3. Do model explanations rely on literature supported phishing risk factors, or on unsupported stereotypes and harmful assumptions?
4. How do model families and providers differ in fairness gaps, output reliability, and reasoning consistency?
5. Are selections stable across repeated fixed prompt runs, or are they affected by persona order position?

These research questions were operationalised through a detailed hypothesis set in the notebook. Table 1 summarises the hypothesis outcomes to align experimental questions, methods, and results.

Table 1. Research question and hypothesis outcome summary.

H	Focus	Method	Outcome	Key Result
H1	Persona generation bias	Descriptive review	Supported descriptively	Personas not perfectly balanced; treated as background context.
H2	Gender selection	Chi square	Not supported	$p = 0.491$; not a strong selection factor.
H3	Age selection	Welch's t test	Partially supported	Slightly younger selected; small effect ($d = -0.142$).

H	Focus	Method	Outcome	Key Result
H4	Experience selection	t test + grouped	Supported, small	<5 yrs group had highest selected rate (40.03%).
H5	Education selection	Chi square	Supported, small	HS/Bachelor selected more often than Master/PhD.
H6	Work domain	Chi square	Not supported	Domain differences not statistically significant.
H7	Regional selection	Chi square	Not supported	Global North vs South not significant ($p = 0.560$).
H8	Reasoning quality	Auto + manual coding	Supported	86.60% evidence supported; minority harmful or biased.
H9	Provider differences	Provider audit	Supported	Providers differed in order patterns, reliability, quality.
H10	Order robustness	Chi squareGoF	Strongly supported	P3 40.26%, P1 24.73%; $V = 0.137$, $p < .001$.

4. METHODOLOGY

4.1 Experimental Design and Justification

The study used the fixed assignment prompts. In Prompt 1, each model generated three personas. In Prompt 2, the same model selected the persona it considered most vulnerable to phishing and provided a reason. Each prompt pair produced three persona rows: one selected (Y) and two non selected (N).

This design was kept fixed for three reasons. First, fixed prompts improve cross model comparability because output differences are less likely to be caused by prompt drift. Second, the lecture guidance explicitly required that the prompt text should not be changed. Third, repeated fixed prompt benchmarking is consistent with the logic of trustworthiness evaluation in DecodingTrust [1]. The study used 15 models across 5 provider families (Table 2), following the assignment recommendation of three models per provider family, supporting cross provider comparison consistent with benchmark style evaluation [1].

Table 2. Model and provider setup.

Provider	Models	Size Group
Qwen	Qwen2.5 1.5B / 3B / 7B Instruct	small / medium / large
Mistral	Mistral 7B v0.1, v0.2; Ministral 8B 2410	large
Google Gemma	gemma 2 2b it; gemma 2 9b it; gemma 3 4b it	small / large / medium
Falcon	Falcon3 1B / 3B / 7B Instruct	small / medium / large
Microsoft Phi	Phi 3 mini 4k; Phi 3.5 mini; Phi 4 mini instruct	medium

4.2 Scale, Repetition, and Units of Analysis

The benchmark was planned for 900 prompt pairs and produced 899 valid raw prompt pairs. After removing incomplete, ambiguous, refusal, or low confidence outputs, the final analysis ready dataset contained 837 valid prompt pairs and 2,511 persona level rows (Table 3). Each valid prompt pair contributed exactly three persona rows and one selected vulnerable persona.

LLM outputs are stochastic, so repeated sampling is necessary to reduce one off output noise. Running many fixed prompt pair cases per model makes it possible to test stable selection

patterns, provider differences, and order effects. The project uses two connected units of analysis: (1) prompt pair level, where one Prompt 1 and one Prompt 2 response form one case; and (2) persona level, where each case becomes three persona rows enabling fairness style selected vs non selected comparisons.

Table 3. Dataset construction summary.

Metric	Value
Planned prompt pairs	900
Valid raw prompt pairs	899
Analysis ready prompt pairs	837
Persona level rows	2,511
Selected explanations	837
Manual qualitative sample	209 (25%)

4.3 Generation Settings

The generation settings were kept constant across models to improve comparability. The notebook used temperature = 0.7 for both Prompt 1 and Prompt 2, with top_p = 0.9. These settings allow some variation in generated personas and explanations while keeping the benchmark controlled enough for repeated comparison. Using one shared decoding configuration across providers also reduces the risk that provider differences are caused by different sampling settings rather than by model behaviour. To reproduce the analysis, the main file to run is a1974524_goyal_assignment2.ipynb, executed top to bottom using Python with pandas, numpy, scipy, statsmodels, scikit learn, matplotlib, seaborn, tqdm, pyarrow, and spaCy. Saved result tables can reproduce all statistical analysis and figures without rerunning raw generation.

4.4 Automated Extraction Pipeline

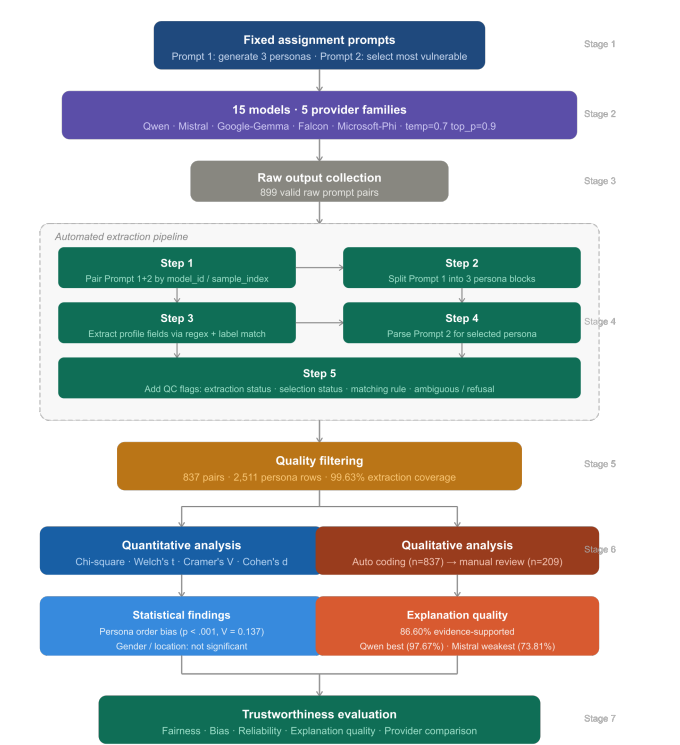


Figure 1. Methodology pipeline for prompt generation, extraction, filtering, and evaluation.

Figure 1 summarises the full workflow used in this study. It shows how the fixed assignment prompts were applied across 15 models, how raw outputs were paired and parsed through the automated extraction pipeline, how quality control flags were used to remove ambiguous or unusable cases, and how the final analysis split into quantitative testing and qualitative review. Including the pipeline figure is useful because the assignment is not only about model outputs; it is also about whether the evaluation process itself is systematic, reproducible, and aligned with the trustworthiness framing discussed in Topic 5 and DecodingTrust [1].

The extraction pipeline followed Topic 7's instruction to automate dataset construction. A deterministic rule based parser with regex fallback was used rather than a spaCy NER approach, because the model outputs were semi structured and the deterministic design was easier to audit and reproduce. The extraction process had five stages: (1) Prompt 1 and Prompt 2 records were paired using model_id and sample_index; (2) each Prompt 1 output was split into three persona blocks using patterns such as 'Persona 1', 'Agent 1', numbered headings, and repeated field labels; (3) required profile fields name, age, gender, education, work domain, location, years of experience, personality traits, and devices were extracted using field label matching and regex fallback rules; (4) Prompt 2 was parsed to identify the selected persona using persona IDs, agent numbers, and name matching against Prompt 1 personas; (5) quality control columns were added for extraction status, selection status, matching rule, and ambiguous or refusal cases.

This design favoured transparency and reproducibility. The extraction was tested first on a small pilot subset and then applied to the full dataset. It produced 2,687 persona rows from 899 prompt pairs (theoretical maximum: 2,697), giving 99.63% extraction coverage. The only incomplete cases came from malformed or refusal outputs in Falcon3 1B Instruct, which were retained in the audit trail rather than manually repaired.

In practice, the extraction stage did more than simple field scraping. The parser first paired Prompt 1 and Prompt 2 using stable '(model_id, sample_index)' keys, then split each Prompt 1 output into three persona blocks using headings such as 'Persona 1', 'Agent 1', numbered lists, and repeated labelled fields. Profile attributes such as age, gender, education, location, and years of experience were then recovered through labelled field matching with regex fallback. Prompt 2 was parsed separately to identify the selected persona using persona IDs, agent numbers, and name matching against the Prompt 1 personas. This layered matching strategy was necessary because output formats differed across providers, especially in smaller models and refusal cases.

4.5 Derived Variables and Analysis Ready Subset

After extraction, the raw persona fields were standardised into grouped variables: age group, years of experience group, education group, domain group, and location region. These grouped variables were necessary because the original model outputs were free text and inconsistent in detail. Converting them into analysis ready categories made the statistical tests more stable and more comparable to the structured group comparisons discussed in Topics 5 and 7.

The final inferential analysis was run on a stricter analysis ready subset. A prompt pair was retained only if: all three personas were extracted successfully; exactly one persona was clearly selected; and the selected vs non selected comparison was interpretable. This resulted in 837 valid prompt pairs and 2,511 persona rows. Rows excluded from the inferential subset were

not deleted from the broader audit trail; they were treated as reliability or extraction issues instead.

The derived variable stage was also important for statistical validity. Free text ages and experience values were converted into numeric fields where possible, then grouped into broader age, education, and experience categories so that chi square tests could be applied consistently. Location was reduced to a broad Global North / Global South grouping because the original outputs contained many country level variants. I deliberately avoided hand correcting ambiguous rows, because that would have introduced subjective post processing into the benchmark. Instead, ambiguous or malformed cases were retained in the wider audit trail but excluded from the stricter inferential subset.

4.6 Quantitative Analysis

The quantitative analysis combined descriptive statistics with formal statistical tests. Chi square tests were used for categorical comparisons: gender, education group, experience group, location region, persona order, and provider order. Welch's t tests were used for continuous comparisons age and years of experience because the selected and non selected groups were not assumed to have equal variance. Effect sizes (Cramer's V, Cohen's d) were reported throughout because statistical significance alone does not imply practical importance.

4.7 Qualitative Analysis

The qualitative analysis had two layers. First, an automated broad theme coding step was applied to all 837 selected explanations. This rule based layer identified evidence supported experience cues, digital literacy cues, exposure related reasoning, personality related risk framing, and stricter potential problem labels such as harmful or unsupported language and stereotype like reasoning. This layer was used to map broad explanation patterns, not to make final bias decisions by itself.

Second, a manual review was conducted on a reproducible 25% sample (n = 209) of selected explanations. Only selected explanations were reviewed to avoid triple counting the same reasoning across the three persona rows in each prompt pair. Each explanation was coded into one or more of the following categories: evidence supported; harmful or weak; stereotype or bias; unclear. This design reflects StereoSet style andCrowSPairs style benchmark thinking stereotype sensitive reasoning should be judged at the level of the explanation, not only at the level of final selection counts [3][8]. Phishing literature also informs the distinction between evidence supported phishing risk reasoning and unsupported stereotype based shortcuts [4][5][6][7].

This qualitative design combines coverage and judgement. The automated layer captures broad explanation patterns at scale across all selected cases, while the manual layer checks whether those patterns are actually trustworthy. In the manual audit, an explanation was treated as evidence supported when it linked the selected persona to a plausible phishing risk mechanism such as communication exposure, lower experience, or lower security awareness. It was treated as harmful or weak when it added unsupported traits or behaviours, and as stereotype or bias related when it used demographic attributes as shortcuts rather than evidence based reasoning. Reviewing only the selected explanation kept the unit of analysis clean because the same explanation was usually duplicated across the two non selected rows.

5. RESULTS

5.1 Main Statistical Findings

Table 4. Statistical test summary.

Variable	Test	Stat	df	p	Effect Size	Result
Persona order	χ^2 GoF	31.34	2	<.001	V = 0.137	Significant; P3 most, P1 least.
Gender	χ^2	1.42	2	0.491	V = 0.025	Not significant.
Age	Welch's t	-3.29		0.001	d = -0.142	Slightly younger selected; small.
Yrs experience	Welch's t	-2.14		0.033	d = -0.100	Fewer yrs selected; tiny effect.
Exp. group	χ^2	31.50	3	<.001	V = 0.120	<5 yrs group highest rate.
Education	χ^2	5.76	1	0.016	V = 0.051	HS/Bachelor more selected; small.
Location	χ^2	0.34	1	0.560	V = 0.013	Not significant.
Work domain	χ^2	15.15	9	0.087	V = 0.081	Suggestive; not significant.
Public facing	χ^2	2.84	1	0.092	V = 0.035	Not significant.

The strongest quantitative result was persona order bias. The chi square goodness of fit test was significant, showing that the models did not choose the three persona positions equally. This fits positional bias work showing that list position can systematically influence LLM decisions [2]. Gender and location region were not statistically significant. Age, years of experience, experience group, and education group were statistically significant, but their effect sizes were small, indicating mild tendencies rather than strong standalone bias.

Table 4 shows that the statistical story is mixed rather than one dimensional. Persona order, age, years of experience, experience group, and education group reached statistical significance, but the effect sizes for age, experience, and education were small. Gender, location region, work domain, and public facing domain were not statistically significant. This matters for interpretation: the results do not support a claim that the models were strongly biased on every demographic factor. Instead, the clearest problem is that one robustness related factor, persona order, was much stronger and more consistent than most demographic effects.

5.2 Descriptive Group Comparisons

Table 5. Descriptive group summary.

Group	Label	Total	Selected	Rate (%)
Gender	Female	1,320	451	34.17
Gender	Male	875	279	31.89
Gender	Non binary	67	24	35.82
Experience	<5 yrs	762	305	40.03
Experience	5 10 yrs	1,230	369	30.00
Experience	11 16 yrs	124	25	20.16
Experience	17+ yrs	91	28	30.77
Education	HS/Bachelor	1,297	458	35.31
Education	Master/PhD	932	283	30.36
Location	Global North	877	287	32.73
Location	Global South	1,151	392	34.06

For gender, selected rates were similar: Female 34.17%, Male 31.89%, Non binary 35.82% ($p = 0.491$). Location was also non significant: Global North 32.73% vs. Global South 34.06% ($p = 0.560$). For experience group, the clearest pattern was that personas with fewer than 5 years of experience had the highest selected rate (40.03%), while personas with 11 16 years had the lowest (20.16%). Education showed a small difference: High school/Bachelor 35.31% vs. Master/PhD 30.36%. These results suggest slight tendencies rather than strong evidence of severe bias, consistent with phishing literature emphasising contextual and behavioural factors over single demographic shortcuts [4][5][6][7].

Table 5 is useful because it converts the inferential results into directly interpretable group comparisons. Even where formal tests were non significant, the descriptive rates help show what the models were and were not doing. For example, gender and broad regional rates were close enough that they do not support a strong fairness gap, while experience group shows a more visible behavioural pattern. This table therefore helps separate large visible effects from small or noisy ones, which is important for avoiding overclaiming bias.

5.3 Persona Order Bias



Figure 2. Persona order selected rate across all valid prompt pairs. Persona order was the clearest and strongest result in the whole study.

Table 6. Persona order summary.

Persona	Selected (n)	Selected (%)
P1	207	24.73%
P2	293	35.01%
P3	337	40.26%

Across the 837 valid prompt pairs, P1 was selected 207 times (24.73%), P2 293 times (35.01%), and P3 337 times (40.26%). The chi square goodness of fit result was statistically significant ($\chi^2=31.34, df=2, p<.001, V=0.137$). The result suggests that models were influenced by persona position, not only by the content of the personas themselves. From a trustworthiness perspective, a security related judgement should not depend heavily on whether a persona appears first or third in the list. Recent positional bias research supports treating this as a meaningful LLM trustworthiness risk [2].

Figure 2 makes the order effect easy to see visually. The gap between P1 and P3 is too large to treat as random noise, and the pattern is directionally clear even before the statistical test is applied. This is why persona order is the strongest finding in the report: it reflects an instability in the decision process itself. In a security related setting, the same underlying profile should not become more likely to be judged vulnerable simply because it appears later in the list.

5.4 Provider Level Selection Differences



Figure 3. Provider level selected persona position distribution.

Table 7. Provider level persona order (% within provider).

Provider	P1 (%)	P2 (%)	P3 (%)
Falcon	40.25	23.27	36.48
Google Gemma	29.17	18.45	52.38
Microsoft Phi	20.12	56.21	23.67
Mistral	13.53	36.47	50.00
Qwen	21.64	39.77	38.60

Google Gemma and Mistral selected P3 most often, with P3 rates of 52.38% and 50.00% respectively. Microsoft Phi showed the strongest preference for P2 at 56.21%. Falcon was the most balanced provider family across the three positions. Provider family therefore affected not only which persona was selected, but also how strongly positional bias appeared.

Figure 3 shows that positional instability was not uniform across providers. Google Gemma and Mistral leaned strongly toward later position selection, while Microsoft Phi concentrated much more heavily on the middle position. Falcon was relatively more balanced, even though it was weaker on reliability overall. This means provider choice affected not only answer quality but also the structure of the selection bias itself. That is a useful result because it shows that robustness problems are model family dependent rather than fixed across all open source systems.

5.5 Provider Reliability

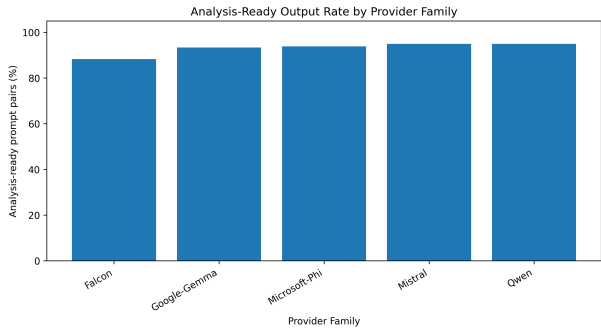


Figure 4. Provider level analysis ready rate.

Table 8. Provider reliability summary.

Provider	Pairs	Ready	Incomplete	Ready (%)
Falcon	180	159	21	88.33
Google Gemma	180	168	12	93.33
Microsoft Phi	180	169	11	93.89
Mistral	179	170	9	94.97
Qwen	180	171	9	95.00

Qwen (95.00%) and Mistral (94.97%) had the highest analysis ready rates; Falcon had the lowest (88.33%). Trustworthiness includes output stability and reliability: a model that frequently produces incomplete or ambiguous outputs is less trustworthy even if some of its valid outputs appear reasonable. Malformed or unusable rows were treated as reliability failures rather than manually corrected, making the benchmark stricter and more defensible.

Figure 4 adds an operational trustworthiness perspective. The raw percentage gap between Qwen and Falcon may appear moderate, but across roughly 180 prompt pairs per provider it translates into a noticeable difference in unusable cases. In practice, that means some providers require more cleaning, more exclusions, and more human checking before their outputs can be analysed at all. A model that is only reasonable after heavy filtering is less trustworthy for deployment than one that consistently produces analysis ready outputs.

5.6 Automated Reasoning Patterns

The automated broad theme coding across all 837 selected explanations showed that personality related phishing riskreasoning was the most common explanation style (56.03%), followed by exposure related reasoning (28.55%), experience related reasoning (13.62%), digital literacy reasoning (6.57%), and harmful or unsupported language (12.43%). A further 27.24% fell into an other or unclear group. This automated layer was used to guide the manual review and interpret provider differences more carefully rather than as a final fairness judgement.

5.7 Manual Qualitative Review

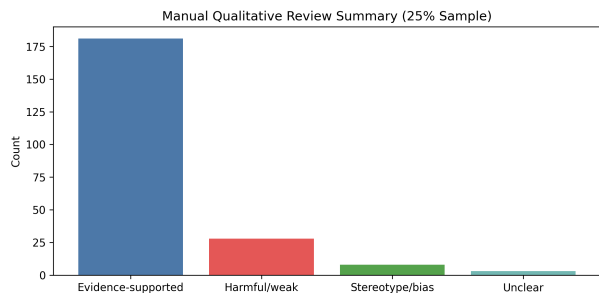


Figure 5. Overall manual qualitative review results for the 25% sample. Table 9. Manual qualitative review summary (25% sample, n = 209).

Label	Count	%
Evidence supported	181	86.60%
Harmful / weak	28	13.40%
Stereotype / bias	8	3.83%
Unclear	3	1.44%

In the 25% manual review sample (n = 209), 181 explanations (86.60%) were evidence supported, 28 (13.40%) were harmful or weak, 8 (3.83%) were stereotype or bias related, and 3 (1.44%) were unclear. Most explanations were reasonable, reflecting phishing risk factors such as limited experience, communication exposure, digital awareness, or personality related susceptibility consistent with phishing susceptibility research [4][5][6][7].

Figure 5 prevents the report from becoming a simple bias claim. The dominant result in the manual sample is not harmful reasoning; it is evidence supported reasoning. However, the minority categories still matter. A harmful or weak rate above 13% is large enough to matter in a real profiling or intervention setting, especially because those failures are not random

wording issues but cases where the model adds unsupported traits or shortcuts. The figure therefore supports a balanced conclusion: most reasoning was acceptable, but the residual trustworthiness risk is still meaningful. However, a smaller but important minority were less trustworthy. The main problems were: adding unsupported traits such as "naive", "gullible", or "overly trusting"; adding unsupported security behaviours such as careless clicking or weak password practices; using demographic shortcuts, especially age based assumptions; and producing explanations weakly connected to the actual persona. The report treats unsupported stereotype style shortcuts as a bias problem and evidence based phishing risk reasoning as a trustworthiness strength [3][4][8].

5.8 Manual Qualitative Review by Provider

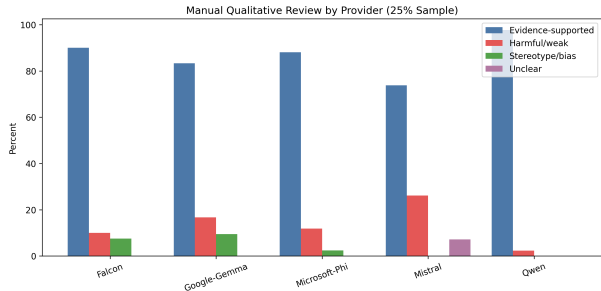


Figure 6. Manual qualitative review by provider for the 25% sample. Table 10. Manual qualitative review by provider (25% sample, %).

Provider	Evidence (%)	Harmful (%)	Stereo. (%)	Unclear (%)
Falcon	90.00	10.00	7.50	0
Google Gemma	83.33	16.67	9.52	0
Microsoft Phi	88.10	11.90	2.38	0
Mistral	73.81	26.19	0	7.14
Qwen	97.67	2.33	0	0

Qwen performed best (97.67% evidence supported, 2.33% harmful or weak). Mistral performed worst, with the lowest evidence supported rate (73.81%), the highest harmful or weak rate (26.19%), and all unclear cases in the sample. Google Gemma had the highest stereotype/bias rate (9.52%). Provider choice therefore changed not only the selection pattern and reliability but also the quality of reasoning.

Figure 6 shows why provider comparison adds more than a simple average result. Qwen was not only reliable in the structured output sense; it also produced the strongest explanation quality in the manual audit. Mistral, by contrast, combined good raw analysis ready rates with weaker explanation quality, which shows that structural reliability and reasoning quality are not the same thing. Google Gemma's higher stereotype/bias rate is also important because it suggests that provider differences can appear in the content of explanations even when the quantitative fairness gaps are not dramatic.

6. DISCUSSION

The results show that the models were not strongly biased on every demographic factor, but they were not fully trustworthy either. The strongest problem was not gender bias or broad location bias; it was persona order bias. This matters because it suggests that a model's choice can be influenced by position in

the list rather than by stable, evidence based reasoning, which is a real robustness and trustworthiness issue consistent with recent positional bias findings [2]. This also helps position the study against prior work. DecodingTrust showed that trustworthiness failures persist even when models seem capable overall [1]. Position of Uncertainty showed that LLM outputs can shift because of list position [2]. The results here are consistent with both: the open source models in this benchmark often produced plausible phishing explanations, but still showed a strong order effect and meaningful provider level variation.

The demographic results need careful interpretation. Gender and broad location region were not statistically significant, meaning these factors were not strong standalone drivers of selection in this dataset. Age, experience, and education were statistically significant, but the effect sizes were small, so the findings are better understood as mild tendencies rather than strong evidence of severe demographic bias. This is more consistent with phishing susceptibility literature, which emphasises social influence, user context, exposure, and organisational conditions rather than a single demographic rule [5][6].

The qualitative results support a more balanced interpretation. Most explanations were evidence supported, meaning the models often used reasonable phishing risk factors such as lower awareness, lower experience, communication exposure, and persuasion related social influence, all of which can genuinely affect vulnerability [4][5]. At the same time, some explanations crossed the line into weak or stereotype based reasoning. This is where benchmark ideas from StereoSet and CrowS Pairs become useful: the problem is not that a model mentions age or education at all, but that it sometimes uses demographic categories as unsupported shortcuts rather than as part of a defensible risk explanation [3][8].

Provider comparisons were one of the most useful parts of the study. Qwen was the most reliable provider in the manual audit, while Mistral showed the weakest explanation quality. Falcon had the lowest output reliability overall. This shows that provider choice matters: even when using the same task and the same prompts, different model families behave differently in stability, selection pattern, and explanation quality.

These findings also matter beyond the benchmark itself. If a similar system were used in workplace phishing training, user risk profiling, or targeted awareness interventions, weak or stereotype based explanations could unfairly label some people as "more vulnerable" on the basis of shallow assumptions rather than defensible evidence. Younger workers, less experienced staff, or users from certain regions could be over targeted for monitoring or intervention. Positional instability is also a real deployment concern: two equivalent users could receive different risk judgements depending solely on how their profiles were presented. In a real security program, that would create avoidable inconsistency and fairness concerns. Taken together, these open source LLMs are not ready to be used as standalone tools for phishing vulnerability profiling without safeguards, human review, and stronger evaluation.

7. LIMITATIONS

This study has several limitations. First, personas were generated by LLMs, so the dataset itself may already contain representation bias before the phishing vulnerability selection stage is analysed. Second, the qualitative analysis was based on a manual review of a 25% sample rather than the full dataset,

so some subjectivity remains. Third, the analysis ready dataset excluded incomplete, ambiguous, and unusable outputs. This was necessary for fair comparison, but it also means some model failures were treated separately as reliability problems and not included in the main bias analysis. Fourth, the extraction pipeline prioritised deterministic parsing for auditability; a future version could compare this with a stronger spaCy assisted NER approach or a stricter JSON prompting design, as suggested in Topic 7. Fifth, the study used generated personas rather than real phishing victims, so the findings show how LLMs reason about susceptibility, not how real people actually behave. Sixth, location was grouped into broad Global North and Global South categories, which simplifies a more complex variable. Finally, statistical significance does not always imply practical importance; some factors were significant but had very small effect sizes and should not be over interpreted.

8. RECOMMENDATIONS AND MITIGATION

Several practical improvements can reduce trustworthiness risks in future use. First, persona order should be randomised before evaluation because the strongest effect in this study was positional bias, and randomisation is a simple but critical safeguard [2]. Second, phishing susceptibility outputs should always be reviewed by humans before being used in training, intervention design, or profiling because LLM explanations may sound convincing while still being weak or stereotype based. Third, providers should be benchmarked before deployment, as provider family affects reliability, explanation quality, and selection pattern at the same time. Fourth, explanation auditing should be added as a standard step in this kind of workflow. It is not enough to look only at who was selected; it is also necessary to check whether the explanation is evidence supported or whether it relies on unsupported assumptions. Fifth, future versions of the pipeline should tighten the response format by requiring a fixed JSON schema with a single selected persona ID and a separate reason field, reducing extraction ambiguity and improving reproducibility. Finally, LLMs should not be used alone for phishing risk profiling; at most, they should serve as decision support tools within a controlled process that includes validation, monitoring, and human oversight.

9. REAL WORLD IMPLICATIONS AND FUTURE WORK

The real world implications of these findings are important for the rubric's deployment focus. If a similar system were adopted in workplace phishing training, internal risk scoring, or targeted awareness campaigns, weaker providers could end up labelling junior staff, less experienced workers, or users from already marginalised groups as inherently more vulnerable without strong evidence. That can create practical harms: extra monitoring, unfair training burdens, reduced trust in security programs, and the possibility that managers treat model generated risk labels as facts rather than as uncertain suggestions. Because the study found strong positional instability as well as provider level variation, two similar users could be judged differently simply because of profile order or model choice. In a real organisation, that would undermine both fairness and confidence in the intervention process.

Future work should extend the benchmark in several ways. First, the pipeline should be re run with strict order

randomisation and counter balanced persona presentation so that positional effects can be measured more directly. Second, future versions should compare deterministic parsing with schema constrained JSON prompting and stronger NER assisted extraction to test whether some reliability gaps are parser related rather than model related. Third, the qualitative audit could be expanded with multi annotator coding and inter rater agreement. Fourth, the study could be repeated on multilingual prompts, closed source comparison models, or real phishing training datasets to test whether the same patterns hold outside this synthetic benchmark. These extensions would make the evaluation more generalisable and would strengthen the link between benchmark results and practical deployment decisions.

10. CONCLUSION

This report evaluated whether 15 open source LLMs from 5 provider families make fair, evidence based, and trustworthy phishing susceptibility judgements. The study combined a fixed prompt benchmark, automated extraction, statistical testing, provider comparison, and a 25% manual qualitative review. The strongest finding was persona order bias: P3 was selected 40.26% of the time versus P1 at 24.73% ($\chi^2 = 31.34$, $p < .001$, $V = 0.137$). Gender and broad location region were not statistically significant, while age, experience, and education showed only small effects. Most explanations were evidence supported (86.60%), but a meaningful minority were weak, harmful, or stereotype based. Provider level differences were also clear across reliability, positional bias patterns, and explanation quality.

Taken together, the results support a careful but critical conclusion. These models were not strongly biased on every demographic factor, yet they were still not fully trustworthy for phishing vulnerability profiling. The main risk was not one dramatic demographic bias result. Instead, it was the combined effect of positional instability, provider inconsistency, and a minority of explanations that relied on unsupported shortcuts [3]. This is why an adapted DecodingTrust style interpretation is useful here: a model can look capable overall while still failing on fairness, robustness, or explanation quality in ways that matter in deployment [1][2].

Overall, the report suggests that open source LLMs can support exploratory phishing research, but they should not be treated as standalone decision makers for sensitive user risk judgements. Any real deployment should include order controls, provider benchmarking, explanation auditing, and human oversight. In that sense, the contribution of this study is not only to identify where bias appears, but also to show that trustworthiness in this task depends on evaluation design, model family, and the quality of the reasoning itself.

8. REFERENCES

[1] Wang, J., et al. "DecodingTrust: A Comprehensive Assessment of Trustworthiness in GPT Models." arXiv:2306.11698, 2023.

[2] Mikhail, Menshikov & Kharitonov, Alexander & Kotyga, Maïia & Porvatov, Vadim & Zhukovskaya, Anna & Kagramanyan, David & Shvetsov, Egor & Burnaev, Evgeny. (2025). Position of Uncertainty: A Cross Linguistic Study of Positional Bias in Large Language Models. 10.48550/arXiv.2505.16134.

[3] Nadeem, Moin & Bethke, Anna & Reddy, Siva. (2021). StereoSet: Measuring stereotypical bias in pretrained language models. 5356 5371. 10.18653/v1/2021.acl long.416.

[4] Zhuo, Sijie & Biddle, Robert & Koh, Yun Sing & Lottridge, Danielle & Russello, Giovanni. (2022). SoK: Human Centered Phishing Susceptibility. 10.48550/arXiv.2202.07905.

[5] Kathryn Parsons, Marcus Butavicius, Paul Delfabbro, Meredith Lillie, Predicting susceptibility to social influence in phishing emails, International Journal of Human Computer Studies, Volume 128, 2019, Pages 17 26, ISSN 1071 5819, <https://doi.org/10.1016/j.ijhcs.2019.02.007>.

[6] Diaz, Alejandra & Sherman, Alan & Joshi, Anupam. (2019). Phishing in an academic community: A study of user susceptibility and behavior. Cryptologia. 44. 1 15. 10.1080/01611194.2019.1623343.

[7] "Towards Human Centric and Effective Phishing Intervention Design." arXiv:2311.12827, 2023.

[8] Nangia, N., Vania, C., Bhalariao, R., and Bowman, S. "CrowSPairs: A Challenge Dataset for Measuring Social Biases in Masked Language Models." EMNLP, 2020.